Ingeniería Social Laboratorio No.5

Principios

1. **Definición de los elementos del escenario**

Elemento	**Definición**
Contexto	Proceso de autenticación rutinario en el sistema SAC.
Objetivo	Obtener credenciales (capturar la contraseña actual y la nueva).
Canal	Correo electrónico
Pretexto	Cumplimiento de la política de seguridad que exige la renovación periódica de la contraseña.
Identidad / Rol	Sistema automatizado del SAC o mesa de ayuda de TI.
Mecanismo de persuación	Confianza (simula un proceso normal y habitual) y Urgencia (advertencia de pérdida de acceso).
Acción solicitada	Acceder a un enlace e ingresar los datos de autenticación bajo la excusa de actualizar la clave.
Clasificación principal	Phishing.
Técnicas complementarias	Pretexting (uso de una historia familiar para el usuario).
Indicadores de alerta	Enlace externo que no coincide con el dominio real del SAC, remitente inusual para notificaciones automáticas y solicitud de actuar desde el correo en lugar del portal de inicio de sesión habitual.
Medida preventiva	No hacer clic en el enlace del correo; ingresar directamente escribiendo la URL del SAC en el navegador para verificar si el sistema realmente solicita el cambio al iniciar sesión.

2. **Redacción de la situación**

Un usuario recibe un correo electrónico que aparenta ser una notificación automática del sistema SAC. El asunto del mensaje es "Aviso de Seguridad: Renovación obligatoria de contraseña". En el cuerpo del correo, se le informa que, de acuerdo con las políticas de seguridad institucionales, su contraseña actual caducará en 24 horas tras cumplir su ciclo de vigencia. El mensaje incluye instrucciones detalladas y un botón que dice "Renovar mi contraseña ahora" para que el usuario pueda establecer una nueva clave y evitar interrupciones en su acceso al sistema.

3. Escenario del compañero

Una persona recibe un mensaje de texto en su teléfono celular que aparentemente proviene de su operador de telefonía móvil. El mensaje le informa que se ha detectado un inconveniente con su servicio y que debe realizar una verificación para evitar una posible suspensión temporal de la línea.

El mensaje indica que la verificación debe realizarse durante las próximas horas y proporciona un enlace para solucionar el supuesto inconveniente. La persona es invitada a ingresar al enlace y seguir las instrucciones que aparecen allí para mantener activo su servicio.

4. Analizar el escenario recibido

Elemento	Identificación	Justificación
Contexto	Telefonía móvil	El escenario ocurre en el entorno de los servicios de telecomunicaciones personales de la víctima.
Objetivo	Obtener credenciales o información personal	Al dirigir a la víctima a un enlace externo para "solucionar el inconveniente", el atacante busca que la persona entregue datos sensibles.
Canal	SMS	El ataque se distribuye mediante un mensaje de texto al teléfono celular de la víctima.
Pretexto	Inconveniente en el servicio	La historia falsa creada para justificar el contacto es la supuesta detección de un problema técnico en la línea móvil.
Identidad/Rol	Operador de telefonía móvil	El atacante asume el rol y suplanta la identidad de la empresa proveedora del servicio de telecomunicaciones.

Mecanismo de persuasión	Urgencia y Temor	Se presiona al usuario limitando el tiempo para actuar ("durante las próximas horas") y se genera temor ante una consecuencia negativa grave ("posible suspensión temporal").
Acción solicitada	Acceder a un enlace	El mensaje instruye directamente a la persona a ingresar a un link proporcionado en el texto.
Clasificación principal	Smishing	Corresponde a un engaño o variante de phishing distribuido específicamente mediante mensajes de texto.
Técnicas complementarias	Pretexting y Suplantación	Se construye un escenario ficticio creíble (pretexting) haciéndose pasar por una entidad legítima y confiable.
Indicadores de alerta	Urgencia injustificada, amenaza de suspensión y enlace externo	La presión para tomar una decisión inmediata y la presencia de un enlace inesperado para "verificar" un servicio son señales claras de engaño.
Medidas preventivas	No acceder al enlace y verificar por canales oficiales	La acción segura es ignorar el mensaje SMS y verificar el estado de la línea comunicándose directamente con el operador mediante su portal o número oficial.

Comparar los resultados

Al realizar la comparación entre mi matriz de análisis y la tabla de diseño original de mi compañero, evidencié una coincidencia exacta en todos los elementos evaluados. Pude identificar correctamente que la intención del escenario era simular un ataque de Smishing a través de un mensaje SMS, suplantando a un operador de telefonía móvil bajo el pretexto de una falla técnica para obligar a la víctima a entregar información en un enlace externo.

Paso 7. Elaborar una conclusión

¿Fue posible identificar correctamente la intención del escenario?

Sí, el escenario está estructurado de manera clásica para llevar a la víctima hacia una página fraudulenta. La intención es forzar a la persona a abandonar el entorno seguro de su teléfono y entregar datos en un sitio web controlado por el atacante bajo la excusa de una verificación.

¿Qué elementos permitieron reconocer la técnica de ingeniería social?

La identificación de la técnica principal (Smishing) fue posible por la combinación del canal utilizado (SMS) junto con los mecanismos de persuasión. La manipulación emocional es evidente al combinar la autoridad de un supuesto operador con la amenaza de una consecuencia negativa en un marco de tiempo muy corto.

¿Qué aspectos resultaron ambiguos?

El escenario no detalla exactamente qué solicita el enlace una vez se ingresa (si es descargar un archivo malicioso, ingresar credenciales o proporcionar datos de tarjetas de crédito). Por lo tanto, aunque la acción solicitada es clara, el objetivo final exacto deduce de forma general por el contexto de tener que seguir instrucciones.

¿Qué indicadores permitirían a una persona detectar el posible engaño antes de realizar la acción solicitada?

Los principales indicadores de alerta antes de hacer clic son: la fuerte presión temporal, la amenaza inusual de suspender un servicio vital mediante un simple mensaje de texto, y, fundamentalmente, la URL del enlace proporcionado, que muy probablemente no coincidirá con el dominio web institucional y oficial del operador de telefonía.